

Botium Toys – Internal Security Audit Report

Prepared by: Chijioke Onwuvuariri

Date: November 25, 2023

Executive Summary

Botium Toys currently has a high-risk security posture with a risk score of 8/10. Multiple critical gaps were identified in asset management, security controls, and regulatory compliance.

Scope and Goals of the Audit

Scope: The scope covers the entire security program at Botium Toys, including all assets managed by the IT department, internal processes, and compliance with relevant regulations (PCI DSS and GDPR).

Goals: Assess existing assets, evaluate current security controls, identify compliance gaps and provide recommendations to improve security posture

Current Assets

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Risk Assessment

Risk Score: 8/10 (High Risk)

Main issues include inadequate asset management, lack of proper controls, and potential non-compliance with U.S. and EU regulations.

Controls Assessment Checklist

Control	Status
Least Privilege	No
Disaster recovery plans	No

Password policies	No
Separation of duties	No
Firewall	Yes
Intrusion detection system (IDS)	No
Backups	No
Antivirus software	Yes
Manual monitoring, maintenance, and intervention for legacy systems	No
Encryption	No
Password management system	No
Physical locks (offices, storefront, warehouse)	Yes
CCTV surveillance	Yes
Fire detection/prevention	Yes

Compliance Checklist

PCI DSS (payment Card Industry Data Security Standard)

Only authorized users have access to customers' credit card information	No
Credit card information is stored/processed in a secure environment	No
Implement data encryption procedures	No
Adopt secure password management policies	No

GDPR (General Data Protection Regulation)

E.U. customers' data is kept private/secured	Partial
There is a plan to notify E.U. customers within 72 hours in case of breach	Yes
Ensure data is properly classified and inventoried	No
Enforce privacy policies and procedures	Yes

SOC (System and Organizations Controls)

User access policies are established	Partial
Sensitive data (PII/SPII) is confidential/private	No
Data integrity ensures the data is consistent, complete, and validated	Yes
Data is available to individuals authorized to access it	Yes

Key Recommendations

1. Implement Least Privilege and Separation of Duties
2. Deploy encryption for credit card and customer data
3. Establish automated backups and disaster recovery plan
4. Strengthen password policy and implement centralized password management
5. Install an Intrusion Detection System (IDS)
6. Conduct regular security awareness training

Conclusion: Immediate action on the above recommendations is strongly advised to reduce risk and achieve better compliance.